Rough Draft — Solution

Category: WEB | Points: 100 | Author: Jerit3787

Overview

The portfolio site is served by nginx. An internal Vite dev server is proxied behind `/dev/`. The Vite `server.fs.deny` can be bypassed with a `?raw??` query (the CVE-2025-30208 class; the challenge pins Vite 6.2.2, inside the vulnerable range).

Steps

1. Visit the site at `:3000` — a static portfolio with no obvious attack surface.
2. Check `/robots.txt` — reveals two disallowed paths: `/backup/` and `/dev/`.
3. Visit `/backup/` — directory listing shows `db_dump.sql` and `config.env.bak`. These contain fake credentials and bcrypt hashes that lead nowhere (red herring).
4. Visit `/dev/` — a preview environment is running (Vite dev server proxied through nginx).
5. Try `/dev/.env` — blocked by `server.fs.deny`.
6. Bypass with `?raw??`: `GET /dev/.env?raw??` — returns the raw `.env` contents including the flag (injected from `FLAG` at container start).

Red Herrings

- `/backup/db_dump.sql` — contains bcrypt hashes for users/API keys. All are fake and uncrackable.
- `/backup/config.env.bak` — contains old database credentials that don't connect to anything.

Flag

```
gctf26{r4w_d0gg1ng_th3_v1t3_d3v_s3rv3r}
```